Leaked ci-deployer key used to read the customer exports bucket

The access key of IAM user ci-deployer was pushed to a public repository on 2026-09-12 20:41 UTC. An external address used it 26 minutes later, created a backdoor user and read 1 090 objects (2.31 GB) of customer exports for July and August 2026. The client disabled the key on 2026-09-13 09:41 UTC; the actor made no successful call after that. The database password from the same file is not yet proven rotated.

CLIENT	INCIDENT	OPENED
Example Corp	inc-0042	2026-09-13T08:10Z
REPORT	**SEVERITY**	**STATUS**
2026-09-14 11:30Z	SEV-2	Contained
EVIDENCE UP TO		
2026-09-14 07:58Z		



SEV-2
Severity, SEV-1 is the highest

26 min
from the public push to the first use of the key

10.7 h
until the first GuardDuty finding

12 h 34 min
the actor had access (dwell time)

2.31 GB
read from exampleco-customer-exports

0
successful actor calls after the key was disabled

01 What happened

12 Sep 20:41	12 Sep 21:07	12 Sep 21:19	12 Sep 21:24	13 Sep 09:41
Key exposed	**Attacker in**	**Backdoor**	**Data read**	**Stopped**
A cloud access key lands in a public code repository	An external address starts using the key	The attacker creates an extra user to keep access	Customer export files are downloaded through the night	The client disables the key and deletes the backdoor user

02 Answers to the key questions

How did the attacker get in?

Confirmed

A developer pushed a file with a cloud access key to a public code repository. An external address started using the key 26 minutes later.

confidence 5/5

Was customer data taken?

Confirmed

Yes. 1 090 customer export files from July and August 2026 were downloaded, 2.31 GB in total. Whether other storage was read cannot be determined, because logging was off there.

confidence 5/5

Is the attacker still inside?

Confirmed

No. The key and the backdoor user were removed on 2026-09-13. Every call after that failed, and no new activity appeared in the following 22 hours.

confidence 4/5

Are other secrets at risk?

Partially

The same file held a database password. We see no proof that it was changed.

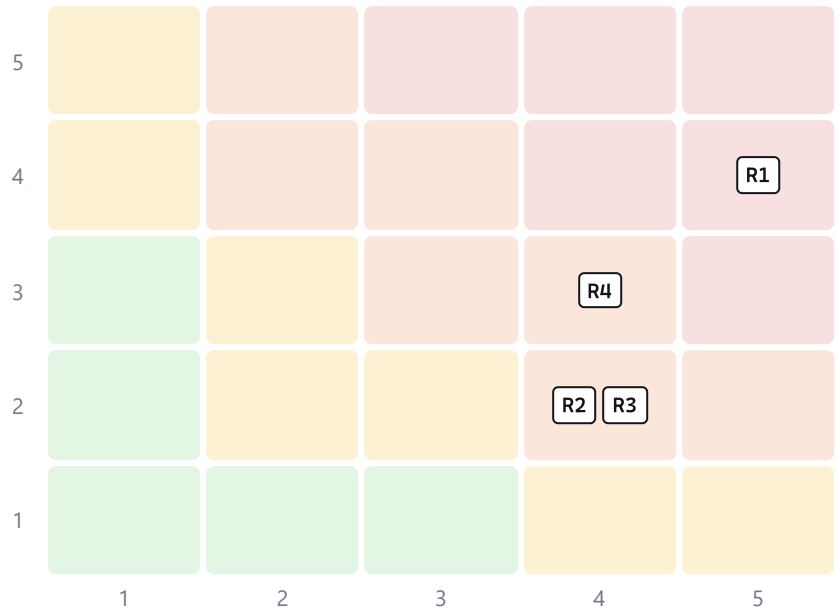
confidence 2/5

03 Progress by NIST SP 800-61 phase



Closed tasks out of all tasks in the case tracker.

04 Remaining risks



Rows: likelihood 1-5. Columns: impact 1-5.

R1 Database password from the same file still valid `item01`

R2 Activity in other cloud regions not visible `G1`

R3 Other buckets read without a trace `G2`

R4 Another key leaks the same way `item01`

05 Decisions we need from you

DECISION	WHY NOW	DEADLINE	OWNER
Decide whether to notify affected customers and the regulator	Customer exports for July and August 2026 were downloaded. GDPR gives 72 hours from awareness (2026-09-13 09:15 UTC)	2026-09-16 09:15 UTC, 45 h 45 min left	DPO, legal
Rotate the database password from the leaked file	Closes risk R1	2026-09-14 18:00 UTC, 6 h 30 min left	Platform team
Enable secret scanning push protection for the organisation	Stops the same leak path (R4)	2026-09-21 00:00 UTC, 6 d 12 h left	Head of engineering

06 What is left to do

PRIORITY	ACTION	WHY	OWNER	STATUS
`Critical`	Rotate the database password from the same .env	`credentials #3`	Client	Not visible in logs
`High`	Remove the .env from git history and enable push protection	`item01`	Client	Not checked

All times UTC Indicators defanged Generated by ir-casekit report.py from the case files